

6.5A Intrusion Detection

Control Type: Advisory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	
<u>Control Definition</u> Control Objective: Detect and contain anomalous network activity into the on-premises or remote Swift environment. In-scope components: • network (data exchange layer reaching the Swift-related components) • remote (that is hosted or operated by a third party, or both) virtualisation or cloud platform supporting the user Swift environment Risk Drivers: • undetected anomalies or suspicious activity						
<u>Implementation Guidance</u> Control Statement: Intrusion detection is implemented to detect unauthorised network access and anomalous activity. Control Context: Intrusion detection systems are most commonly implemented on a network (NIDS)³⁸ – establishing a baseline for normal operations and sending notifications when abnormal activity on the network is detected. As an operational network becomes more complex (for example, systems communicating to many destinations, internet access), so will the intrusion detection capability needed to perform adequate detection. Therefore, simplifying network behaviour is a helpful enabler for simpler and more effective intrusion detection solutions. Host intrusion detection systems (HIDS) are intended to protect the individual system on which they are implemented and to detect network packets on its network interfaces, similar to the way an NIDS operates. Intrusion detection systems (NIDS or HIDS) often combine signature- and anomaly-based detection methods. Some systems can respond to any detected intrusion (for example, terminating the connection). Endpoint and extended detection and response (EDR and XDR) are part of an emerging technology that addresses the need for continuous monitoring and response to advanced threats by detecting suspicious activities and (traces of) other problems on systems, and on endpoints. This technology is more frequently combined with endpoint protection platform (EPP) that operates at the device level while others expand their monitoring capabilities through XDR. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives). • The intrusion detection system is configured to detect anomalous activity at the boundary of the secure zone and ideally within the secure zone. This can be achieved through NIDS, HIDS, EDR, XDR, or a combination of those techniques depending on the network configuration. For example, large VLAN would better benefit from NIDS; isolated island separating systems may benefit from HIDS. The EDR or XDR solution can also be considered, in particular within secure zones. • Network activity to be tracked for intrusion detection analysis may include: – Inbound and outbound connections during non-business hours						

³⁸ Network Intrusion and Detection System

- Unexpected connections from/to the secure zone towards/from systems outside of the perimeter of the Swift or customer secure zone and ideally between systems within the secure zone
- Unexpected port or protocol use (for example, P2P)
- The system has a repeatable process to regularly update known intrusion signatures or its abnormalities detection methods.
- If an intrusion is detected, then an alarm is raised and, if the tool permits, a defence mechanism can be triggered manually or automatically.
- Detected intrusions are managed through the standard incident response process.

Optional Enhancement:

- Intrusion detection systems can inspect encrypted flows.
- Abnormal network activity detection and containment is performed within the secure zone.

Considerations for alternative implementations:

Institutions with a high level of security information and event management (SIEM) maturity within their organisation may consider extending, as stated in the control 6.4, their SIEM for real-time analysis of network and systems intrusion.